Security self-assessment

Zishi, 2026 Shenzhen International FinTech Competition, International Track, Topic F. Structured on the four headings of the official template (international-security-self-assessment-en): 01 Permission Model, 02 Security Tests, 03 Data and Privacy, 04 Known Risks. Every claim names the file that implements it. Where something is a demo shortcut, it says so.

01 Permission Model

Who can do what. Four tiers, enforced in `PolicyEngine.evaluate()` (`web/src/engine/policy.ts`) on every signed intent, and again on chain by the contracts.

Tier	Who	Can	Cannot
L0 read	Anyone, the model	Read prices, balances, messages	Move anything
L1 draft	The model	Write one sentence of explanation	Name a payee or an amount; hold a key
L2 engine allow	The machine key, through 21 rule lines	Sign typed intents that pass every line: signature, replay, amount, provenance, allowlist, lookalike, instalment payee, per transaction cap, reserve rule	Raise its own cap, add a payee, spend outside the allowlist
L3 operator	The pilot's operator key, behind the physical button step	`set_cap`, `top_up`, one displayed action at a time	Move the lease rate outside the signed band (`Lease.setRate`)

Keys. Five keys with separate roles (machine, operator, lender, vendor, farmer). The model process holds none. In this demo the keys are derived from fixed public strings in `web/src/engine/keys.ts` so runs replay to the same hash chain and the same intent hashes land on both ledgers. That makes them demo-only: anyone can derive them and sign as any actor. Production keys: the machine key in the drone's secure element, the operator key in a hardware device, the lender key in the lessor's HSM, the vendor key in our HSM, rotation through `Bond.register` by the operator.

Routes that act. Real chain mode (`/api/run`) and the L3 button (`/api/button`) require the demo token (header `x-zishi-demo`, compared with the `DEMO_TOKEN` deployment secret; unset means always refused). A public visitor gets the simulated chain and a refused button. The judge console (`/api/judge`) caps the body at 64 KiB and never touches a wallet.

On chain. `Bond.slashByProof` reads every fact from the signed intent, `IntentLog`, `JobBoard` and `Lease`; the reporter only names the rule and must be a party of the job (hunters only on shadow jobs). `Bond.topUp` is operator only. Each intent hash can be used once (spent set).

Trust boundaries.

Boundary	What crosses it	Defence
Counterparty to agent	Messages, invoices, tool results	Escaped and framed as data; judge gate (rules plus classifier) before the agent reads it
Model to engine	One sentence	Number grounding check, template fallback, no key in the model process
Agent to wallet	Typed EIP-712 intents	Policy engine, every rule a line; allow or nothing moves

Boundary	What crosses it	Defence
Engine to chain	Transactions	Intent hash committed to `IntentLog` first; contracts re-check rules; slash only by proof
Operator to engine	Cap and top up	Operator only rule, button step, demo token on the route, band check
Learned components to engine	Risk score, anomaly score, plan, strategy numbers	Scores can only add a hold; plan re-checked per job by `economics()`; the ratchet cannot cross the reserve rule

02 Security Tests

Test	What it covers	Where	Result
Attack set	52 cases at three layers: message (injection, impersonation, payee in text, Chinese variants), policy (over cap, off allowlist, lookalike, replay, forged signer), contract (slash rules, not a party, proof reuse, not in log)	`web/src/engine/attacks.ts`, run in `pnpm test` and on every load of the Evidence page	52 of 52 blocked by the full pipeline; see `docs/RED_TEAM.md` (generated)
Benign set	Ordinary requests through the same gate must pass	same	7 of 7 pass
Classifier held out	Injection classifier on a held out split disjoint from training; the attack texts are not in the training corpus	`web/src/engine/ml/gate.ts`, `docs/EVALUATION.md`	87 held out: precision 100% (26 of 26, interval 87.1 to 100), recall 81.3% (26 of 32, 64.7 to 91.1), false alarm 0 of 55 (0 to 6.5). On the 52 attack texts, never trained on: the classifier alone holds 13; the full pipeline blocks 52
Flight log oracle	Tamper detection and false alarms on synthetic flights	`web/src/engine/ml/plausibility.ts`, `oracle.ts`, `docs/EVALUATION.md`	500 synthetic held out flights, seed 7331: detection 72 of 72 (94.9 to 100%), false alarm 13 of 428 honest (3.0%, 1.8 to 5.1%)
Fail safe on missing data	A missing or degraded sensor channel holds the fee instead of imputing it	`oracle.ts`, `selfcheck.ts`	Held, with a reason
Solidity tests	Contract rules, fuzzed amounts, nonces and payees; contract layer attacks ported to Solidity; Lease tests	`contracts/test/*.t.sol`, CI	68 tests, all passing; the 15 contract layer attacks run against Solidity, not only the TypeScript mirrors

Test	What it covers	Where	Result
Full job on chain	Fee locked, confirmed, instalment paid, slash by proof, title at zero, against the deployed contracts	`contracts/script/`, `contracts/deployments/*-fulljob.json`, `docs/EXECUTION_EVIDENCE.md`	Base Sepolia: 9 of 9 contract calls succeeded, value moved; the same job on FISCO BCOS
Evidence verification	Every recorded hash re-fetched from the chain, calldata decoded, balance sheet recomputed	`pnpm verify`, `pnpm fisco`	0 problems on the latest runs
Replay and tamper	Two runs on one seed end on the same hash chain head; an edited entry is caught at its index	`web/src/engine/replay`, `selfcheck.ts`	Caught
Route auth	The L3 button and real mode refuse without the demo token	`selfcheck.ts`	Refused

Run all of it: `cd web && pnpm test && pnpm lint`, `cd contracts && forge test`.

03 Data and Privacy

On chain, hashes only. `IntentLog` stores an intent hash, a job id hash, the committing address and a time. No field location, telemetry, name or phone number goes on chain. The full intent is delivered only to the parties of the job (farmer, pilot, lender, vendor). This is how the design meets the Personal Information Protection Law (PIPL) and the Data Security Law: field coordinates can be personal or business data, so they stay among the parties.

In the demo. All people, fields and flights are synthetic and say so. The FATE credit experiment uses seeded synthetic pilots; three lenders train one model and no lender's rows leave its own process (`fate/README.md`). No raw telemetry is stored by the app; the event log keeps hashes and decisions.

Regulatory map (our reading, to be confirmed by the sandbox lessor's counsel).

Area	Rule	How Zishi fits
Financial leasing (融资租赁)	NFRA: Measures for the Administration of Financial Leasing Companies (金融租赁公司管理办法, 2024); interim measures for financing lease companies (融资租赁公司监督管理暂行办法, 2020)	A licensed leasing company is the lessor and lender of record. Zishi services the contract (repayment per mu inside a signed band, freeze, title at zero); it does not lend
Payments	PBoC: Regulations on Non-bank Payment Institutions (非银行支付机构监督管理条例, 2024)	Fees settle through a licensed bank or payment institution, or e-CNY; the chain records, it does not custody customer funds
Crypto	PBoC notice on virtual currency trading (2021)	No public token for mainland users. Testnet units here are evidence only; production uses a consortium chain (FISCO BCOS) with bank money

Area	Rule	How Zishi fits
Drone operations	CAAC: Interim Regulations on the Flight Management of Unmanned Aircraft (无人驾驶航空器飞行管理暂行条例, 2024) and CCAR-92	The pilot holds the operator licence and the operation certificate, the drone is real name registered, third party liability insurance is in force. The job terms carry these as preconditions; Zishi does not fly the drone
Personal data	PIPL, Data Security Law	Hashes on chain, consent in the job terms, details among the parties
Hong Kong	HKMA (stored value and payments), SFC (virtual asset activities), PDPO (personal data)	A Hong Kong rollout keeps the same split: licensed lessor, licensed payment rail, no token offered to the public, personal data among the parties

04 Known Risks

Risk	Status	Where	Planned fix
`IntentLog.commit` can be front run	Open. `commit` is permissionless and first writer wins per hash with `agentOf = msg.sender`. Anyone who sees an intent hash can commit it first, and `slashByProof` then fails "not in log". A compromised agent can also simply not commit. Mitigation today: the engine commits before the policy engine decides, and parties receive the full intent	`contracts/src/IntentLog.sol`	Commit restricted to the registered agent of the job (`Bond.operatorOf` / `JobBoard` party check) or bound to the job escrow, so only the agent's own commit counts and a missing commit on a paid job is itself slashable. Redeploy with Foundry tests
Demo keys are derivable	Demo only, stated in 01	`keys.ts`	Per actor keys in secure hardware
Engine mirrors	Bond, JobBoard and Lease rules run as TypeScript mirrors inside the live engine; the full job flow runs against the deployed contracts from a Foundry script, with its own evidence table	`web/src/engine/contracts.ts`, `contracts/script/`	Engine calls the contracts through their ABIs; mirrors become the test oracle
Rate limiting	Best effort, in memory per serverless instance	`ratelimit.ts`	Per key quotas behind auth
Oracle on synthetic data	All flights are synthetic; detection numbers carry their n and interval	`ml/plausibility.ts`	Validate on real agricultural drone logs
Classifier corpus	Handwritten by the team; the held out split is disjoint but written by the same people	`ml/corpus.ts`	Held out set written by someone outside the team, then real held messages

Risk	Status	Where	Planned fix
Farmer and pilot collusion	A stated rule, not code	`TECHNICAL.md`	Credit counts a job only when farmer and pilot differ, track and confirmation agree, and the fee came from an address with history
Chain reorg	`RealChain` waits for a receipt and two confirmations on Base	`chain.ts`	Consortium chain finality (FISCO BCOS PBFT is final at commit)
FISCO BCOS	Running as a single local node in Docker with receipts in `docs/FISCO_EVIDENCE.md`; the public demo cannot reach it. FISCO block time is in milliseconds, so JobBoard windows need a unit fix there	`contracts/script/fisco.sh`	A node run by the lessor in a consortium group
Physical damage	Out of scope; the bonds cover rule breaks only	`JobBoard.flag` hold	Drone insurance plus a human dispute path
Model outage	Built fallback: no key, timeout or error means template text; the model never moves money	`model.ts`, `agents.ts`	Same